

Tietoturva-auditoinnin tekninen checklist (POC-ympäristö)

Tämä checklist on laadittu teknistä auditointia varten harjoitusympäristössä (POC). Kysymykset on muotoiltu niin, että niitä voidaan testata käytännössä virtuaalikoneissa ja testiverkossa. Tulokset voidaan dokumentoida rastittamalla kyllä/ei sekä lisäämällä kuvakaappauksia todisteeksi.

Kategoria	Testattava asia	Testausmenetelmä / työkalu	Status (Kyllä / Ei)	Kommentit / Kuva
Salasanakäytännöt	Pakottaako järjestelmä vähintään 8 merkin salasanan?	Järjestelmän asetukset, testikäyttäjän luonti		
Salasanakäytännöt	Sallitaanko heikot salasanat (esim. 1234)?	Testikäyttäjän luonti		
Salasanakäytännöt	Lukittuuko tili useiden virheellisten kirjautumisyritysten jälkeen?	Toistuvat kirjautumisyritykset		
Ohjelmistopäivitykset	Löytyykö asentamattomia päivityksiä?	apt/yum/dnf update, Windows Update		
Ohjelmistopäivitykset	Onko automaattinen päivitys käytössä?	Järjestelmän asetukset		
Varmuuskopiointi	Toimiiko tiedoston varmuuskopiointi?	Tiedoston kopiointi varmuuskopiohakemistoon		
Varmuuskopiointi	Onnistuuko tiedoston palautus varmuuskopiosta?	Palautustesti		
Varmuuskopiointi	Tehdäänkö säännölliset varmuuskopiot kriittisistä tiedoista? (NIST SP 1800-11, NCSC UK)			
Varmuuskopiointi	Onko varmuuskopioiden palautus testattu onnistuneesti? (NIST SP 1800-11)			
Varmuuskopiointi	Säilytetäänkö varmuuskopiot erillään tuotantojärjestelmistä (offline / eri verkossa)? (CIS, NCSC UK)			
Verkkoturva	Näkyykö avoimia portteja?	Nmap-skannaus		
Verkkoturva	Löytyykö tunnettuja haavoittuvuuksia?	OpenVAS / Nessus		
Käyttöoikeudet	Voiko tavallinen käyttäjä asentaa ohjelmia?	Kirjautuminen normaalikäyttäjällä		
Käyttöoikeudet	Onko kotihakemiston tiedostoihin rajoitettu pääsy oikein?	Kokeilu eri käyttäjillä		
Käyttöoikeudet	Onko käyttäjien oikeudet rajattu minimiin ("least privilege")? (CIS, Microsoft)			

Käyttöoikeudet	Voiko tavallinen käyttäjä asentaa ohjelmia ilman admin-oikeuksia? (CIS)			
Lokitus ja valvonta	Kirjaantuuko epäonnistunut kirjautumisyritys lokiin?	Tarkistus syslog/event viewer		
Lokitus ja valvonta	Kirjaantuuko ohjelmistopäivitykset ja varoitukset lokiin?	Lokien tarkastus		
Päivitykset	Onko käyttöjärjestelmä ja ohjelmistot päivitetty viimeisimpään versioon? (CIS, NIST)			
Päivitykset	Onko automaattiset tietoturvapäivitykset käytössä? (CIS, Microsoft)			
Tunnistautuminen	Onko kaksivaiheinen tunnistautuminen käytössä kaikissa kriittisissä palveluissa? (CIS, CISA)			
Valvonta ja reagointi	Kirjaantuuko epäonnistuneet kirjautumiset ja poikkeamat lokiin? (NIST, NCSC UK)			
Valvonta ja reagointi	Onko organisaatiolla suunnitelma kiristyshaittaohjelmatilanteen varalle (incident response)? (NIST SP 1800-11, CISA)			
Valvonta ja reagointi	Onko henkilöstölle annettu ohjeet toimintaan epäilyttävän viestin tai liitetiedoston kohdalla? (CIS, Europol)			